

Threat Model

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

24. Threat Model

Method: STRIDE per element and per trust boundary of the data-flow diagram in Section 29, following Shostack [30]. Likelihood and impact are rated Low / Medium / High by team judgement informed by the secondary research; they are [ASSUMPTION]-grade ratings to be revisited after primary data (e.g., how often guards see suspicious cards, B Q5) and after Phase 2 testing.

24.1 Threat actors

ID	Actor	Capability	Motivation	Access
TA-01	Unauthorised visitor (opportunist)	Social engineering, tailgating, borrowed card	Curiosity, theft, meeting someone, sales	Approaches gate
TA-02	Student using another student's credential	Legitimate-looking holder; knows campus	Convenience (forgot card), helping a friend, letting an outsider in	Has a valid card not their own
TA-03	Attacker with a copied credential	Card reader/writer, Proxmark-class tool, phone with NFC; photo of QR	Persistent access, impersonation	Brief proximity to a victim's card or screen
TA-04	Attacker attempting replay	Sniffing equipment near reader; screenshot of QR	Access without victim's card	Proximity to reader during a legitimate tap
TA-05	Malicious visitor	Valid visitor pass; intent to overstay, roam, or share pass	Theft, harassment, unauthorised presence	Approved for limited window/gate
TA-06	Compromised reader (physical or firmware)	Physical access to reader housing, debug ports; supply-chain tamper	Extract keys, log credentials, force ALLOW	Physical, possibly overnight
TA-07	Compromised user device (phone malware, rooted device)	Malware with app or OS privileges	Steal phone credential, generate tokens remotely	Victim's phone
TA-08	Network attacker	On campus Wi-Fi/LAN or ISP path; MITM, sniffing, DoS	Intercept, modify, replay, deny service	Network between reader and server
TA-09	Database attacker	SQL injection, stolen backup, cloud misconfiguration, credential stuffing on admin	Mass identity data, key material, log manipulation	Remote or via compromised admin
TA-10	Malicious insider (guard, admin, developer)	Legitimate role privileges; knowledge of procedures	Let someone in, look up a person, cover tracks, sell data	Authenticated role account
TA-11	Attacker with physical access to a credential (theft, finding)	Holds the card/phone	Enter as victim before revocation	Until revoked
TA-12	Denial-of-service attacker	Jam RF, flood readers with bad taps, cut power/network, DDoS server	Disrupt campus, force manual mode to exploit it	Near gate or remote

24.2 Assets

ID	Asset	Sensitivity	Where it lives
AS-1	Student identity (name, roll no., programme, photo)	Personal data	Identity store; photo store
AS-2	Credentials (cards, phone enrolments, visitor passes)	Access-enabling	Card chips; phone secure storage; credential table
AS-3	Authentication keys and secrets (per-card AES keys, app signing keys, token signing key, TLS private keys, revocation-list signing key)	Critical secret	HSM/KMS; card chips; phone keystore; reader (own cert only)
AS-4	Access permissions and credential status	Integrity-critical	Credential/status table; offline revocation list
AS-5	Entry logs	Personal data (movement); integrity-critical	Log store
AS-6	Personal information beyond identity (visitor contact)	Personal data	Visitor table (short-lived)
AS-7	Authorization policies	Integrity-critical	Policy store
AS-8	System availability (gate throughput)	Operational	Readers, network, servers
AS-9	Security devices (readers, guard tablets, servers)	Physical + firmware integrity	Gates; server room/cloud

24.3 Threat table

For every threat: scenario, asset, impact, likelihood/priority, mitigation (requirement IDs), residual risk, usability impact.

ID	Threat (STRIDE)	Attack scenario	Asset	Security impact	Likelihood / Priority	Mitigation	Residual risk	Usability impact of mitigation
TH-01	Credential theft (S)	TA-11 finds or steals a card and taps it at the gate before the owner notices	AS-2, AS-4	Unauthorised entry as victim; victim blamed via log	Likelihood M (cards are lost; H5); Priority High	Self-service instant revocation (SEC-17, FR-09); guard photo check against server photo (FR-12); phone credential requires unlock (D1); short propagation (FR-08)	Window between loss and report; guard fatigue skipping photo	Student must know how to report (USE-13); guard must glance at photo (USE-05)
TH-02	Credential cloning (S)	TA-03 reads a MIFARE-Classic-class card or photographs a static QR and writes a clone	AS-2, AS-3	Persistent unauthorised entry; undetectable if UID-based	Likelihood H for weak tech [4, 5], L for AES challenge-response [41]; Priority High	Cryptographic challenge-response with per-card key, never bare UID (SEC-01); dynamic signed QR only (SEC-04); modern chip family (D1); anomaly detection on impossible sequences, e.g., same credential at two gates within minutes (SEC-13)	Future break of chosen chip family; side-channel key extraction [7] with physical possession	None for user; cost of secure cards
TH-03	Replay (S, T)	TA-04 records reader-card exchange or screenshots a QR and presents it later	AS-2	Unauthorised entry	Likelihood M; Priority High	Server nonce in challenge-response (SEC-04); QR tokens time-bound (30–60 s) and single-use cache (SEC-04); visitor pass counters (SEC-16)	Real-time relay within window (see TH-04b); clock skew abuse bounded by NFR-14	Slight: QR must be shown within a minute of generation
TH-04	Impersonation (S)	(a) TA-02 uses a friend's valid card; (b) TA-03 relays a live card/phone from a victim elsewhere [18–20]	AS-1, AS-2	Wrong person admitted; log attributes entry to victim	(a) Likelihood H (social norm; Q12 [DATA REQUIRED]); (b) Likelihood L (skill/equipment); Priority High	Guard compares face to server photo for the authenticated credential (FR-12, USE-05); "Mismatch" button denies and flags (screen 16); phone credential requires unlock, so lending a phone is costlier; velocity/anomaly rules (SEC-13); Phase 2 option: distance-bounding not available commercially, so relay accepted as residual	Guard fatigue or coercion; relay defeats all crypto and is stopped only by the human check	Photo check adds ~0.5 s of guard attention per person; must be designed as a glance
TH-05	Credential sharing / malicious visitor (S, E)	TA-05 forwards visitor QR to a second person, or overstays, or goes to a different gate	AS-2, AS-4	Unapproved person or area; overstay	Likelihood M; Priority Medium	Pass bound to window + gate set + host (SEC-16); single/limited use; guard sees host name and asks if unsure; overstay produces DENY at exit? (exit not controlled: residual); host notified on use (FR-10)	Forwarding within window before first use; overstay inside campus	Visitor must present pass from their own device; host gets a notification
TH-06	Fake credential (S)	TA-01 presents a home-made card or QR that looks right	AS-2	Entry if visual check is the only control	Likelihood H today, L with crypto; Priority High	SEC-01: a fake cannot pass challenge-response → "NOT RECOGNISED" (screen 6); server-side photo means altering printed photo is useless; guard never asked to judge card authenticity	Fake that also carries a cloned key = TH-02	Removes a cognitive load from guards
TH-07	Expired credential reuse (E)	Graduated student or old visitor pass presented	AS-4	Ex-member enters	Likelihood H today (H2), L with enforcement; Priority Medium	Server/reader enforces expiry (SEC-03); visitor auto-expiry (SEC-16, FR-11); distinct "EXPIRED" message and renewal path (screen 7)	Clock manipulation on offline reader (bounded by NFR-14, signed time in list)	Students must renew before expiry; app reminds them
TH-08	Revoked credential reuse (E)	Suspended/withdrawn student, or holder of a reported-lost card, taps	AS-4	Barred person enters	Likelihood M; Priority High	Revocation checked on every decision (SEC-02); propagation ≤30 s online; signed offline list ≤N h (SEC-19); irreversible revocation (SEC-17); "REVOKED" screen without reason (screen 8, SEC-08)	Offline staleness window up to N hours; mitigated by shortening N at cost of more manual mode	None for legitimate users
TH-09	Unauthorised privilege escalation (E)	Guard account used to revoke/issue; admin session hijacked; API called with wrong role	AS-4, AS-7, AS-2	Arbitrary issue/revoke; policy change	Likelihood M; Priority High	RBAC with least privilege and separation of duties (SEC-07); MFA + two-step confirm for admin ops (SEC-11); all admin actions logged (SEC-12); session timeouts	Compromised MFA device; collusion of two insiders	Admin ops take longer (MFA, confirm)

ID	Threat (STRIDE)	Attack scenario	Asset	Security impact	Likelihood / Priority	Mitigation	Residual risk	Usability impact of mitigation
TH-10	Database compromise (I, T)	TA-09 dumps identity, credential and log tables or edits status	AS-1, AS-3, AS-4, AS-5	Mass privacy breach; forged status; key theft enabling cloning	Likelihood M; Priority High	Minimisation limits blast radius (SEC-14, PRIV-01); keys in HSM/KMS not DB (SEC-18, PRIV-11); encryption at rest (PRIV-11); pseudonymous logs with separate mapping table (PRIV-04); integrity-protected logs (SEC-10); parameterised queries, ASVS L2 (NFR-07)	Attacker with HSM access; insider DBA	None for users
TH-11	Network interception (I)	TA-08 sniffs reader-server or app-server traffic	AS-1, AS-3	Learn identities, tokens, nonces	Likelihood M on shared Wi-Fi; Priority Medium	TLS 1.3 mutual auth (SEC-05); no identity in reader-server request beyond credential pseudonym; tokens short-lived	Traffic analysis (who tapped when)	None
TH-12	Man-in-the-middle / rogue server (T, S)	TA-08 impersonates the server to a reader, returning ALLOW	AS-4, AS-8	Reader opens on attacker's command	Likelihood L-M; Priority High	Mutual TLS with pinned server cert on reader (SEC-05); decisions signed by server key and verified by reader; reader never trusts unauthenticated ALLOW (SEC-09)	Compromise of server signing key	None
TH-13	Privacy leakage (I)	Guard screen read by bystanders; roll number displayed; logs browsed casually; visitor register visible	AS-1, AS-5, AS-6	Exposure of identity, movement, contacts	Likelihood H today (H6, public questioning); Priority High	SEC-08/PRIV-03 minimal guard view; PRIV-10 physical screen placement and split user/guard displays; PRIV-04/06 pseudonymous logs with justified re-identification; PRIV-09 no public register; PRIV-05 retention	Guard verbally reveals name; shoulder-surfing of guard tablet	Guard sees less, decides on photo + first name only
TH-14	Denial of service (D)	TA-12 jams RF, floods readers with invalid taps, cuts power/network, or DDoSes the server, to create chaos or force manual mode	AS-8	Queues; pressure to bypass; manual mode exploited by TA-01	Likelihood M; Priority Medium	Offline verification (SEC-19) so network DoS does not stop gate; rate-limiting and SEC-13 escalation for tap floods; battery backup for readers (NFR-03); Manual Verification Mode is defined, logged and not an open gate (FR-14, FR-19); supervisor alert	Sustained physical jamming forces manual mode for its duration	Manual mode is slower (accepted degradation)
TH-15	Log tampering / loss (T, R)	TA-10 deletes an entry to hide a let-in; outage loses events	AS-5	Repudiation; failed investigation	Likelihood M (insider), M (outage); Priority High	Append-only hash-chained logs with signed checkpoints (SEC-10, SEC-15); reader buffers events locally during outage and syncs (FR-14); no delete/edit for any role; write-once storage	Attacker who controls the checkpoint signing key and all replicas	None
TH-16	Device compromise (reader, guard tablet, phone) (T, I, E)	TA-06 opens reader, dumps firmware/keys [36]; installs skimmer; TA-07 malware exports phone credential	AS-3, AS-2, AS-9	Key theft → cloning; forced ALLOW; credential exfiltration	Likelihood M (readers are outdoors, unattended at night); Priority High	Reader holds no master keys (SEC-18); per-reader client cert revocable; signed firmware; tamper switch logged; reader cannot decide ALLOW without server or valid offline material; phone keys in hardware keystore, app refuses to run on rooted device (Phase 2), remote revoke of phone credential (SEC-17)	Sophisticated hardware attacks on secure elements; zero-day on phone OS	None for users
TH-17	Insider abuse (I, E, R)	Guard lets friend through in manual mode; admin looks up a student's movements; issuer creates a credential for a non-member	AS-1, AS-4, AS-5	Unauthorised entry; stalking; ghost identities	Likelihood M; Priority High	Manual decisions logged with guard ID and flagged for review (FR-19); guard cannot override DENY to ALLOW (FR-13); re-identification requires justification, is logged, and is visible to a second admin (PRIV-06); issuance requires roster match and is logged (FR-07, SEC-12); separation of duties (SEC-07)	Collusion; supervisor approving bad manual entries	Manual entries require a supervisor step (slower, by design)

24.4 Trust boundaries and attack surfaces (summary; diagram in Section 29)

Boundary	Between	Crossing data	Controls
B1 Physical	Person/credential ↔ Reader	RF challenge–response; QR image	SEC-01, SEC-04; reader tamper (SEC-18)
B2 Gate LAN	Reader/guard tablet ↔ Campus network	TLS 1.3 mutual (SEC-05)	Cert pinning; signed decisions
B3 Service	Auth service ↔ Policy engine ↔ Stores	Internal API	RBAC service accounts; least privilege
B4 Key custody	Services ↔ HSM/KMS	Key ops only	Keys never leave HSM; audit
B5 Admin	Admin browser ↔ Admin API	MFA sessions	SEC-11, SEC-07
B6 Student	Phone app ↔ Enrolment/API	TLS; device attestation (Phase 2)	Hardware keystore
B7 Visitor	Host/approver ↔ Visitor pass delivery	Signed QR via e-mail/SMS	SEC-16

24.5 Prioritised summary

High priority (design must address in Phase 2 minimum): TH-01, TH-02, TH-03, TH-04, TH-06, TH-08, TH-09, TH-10, TH-12, TH-13, TH-15, TH-16, TH-17. Medium: TH-05, TH-07, TH-11, TH-14.

Accepted residual risks, stated plainly: (1) real-time relay attacks are not prevented cryptographically and rely on the guard's photo check and anomaly detection; (2) a guard who is coerced, colluding or fatigued can fail the photo check; (3) revoked credentials may work at an offline reader for up to N hours; (4) a future cryptanalytic or side-channel break of the chosen card family would require re-issuance, which the lifecycle design makes possible but not free; (5) the system does not control exit and cannot detect overstay by visitors.

Figure J-9. Threat model as an attack tree. Root: unauthorised entry. Leaves show the controlling requirement(s).

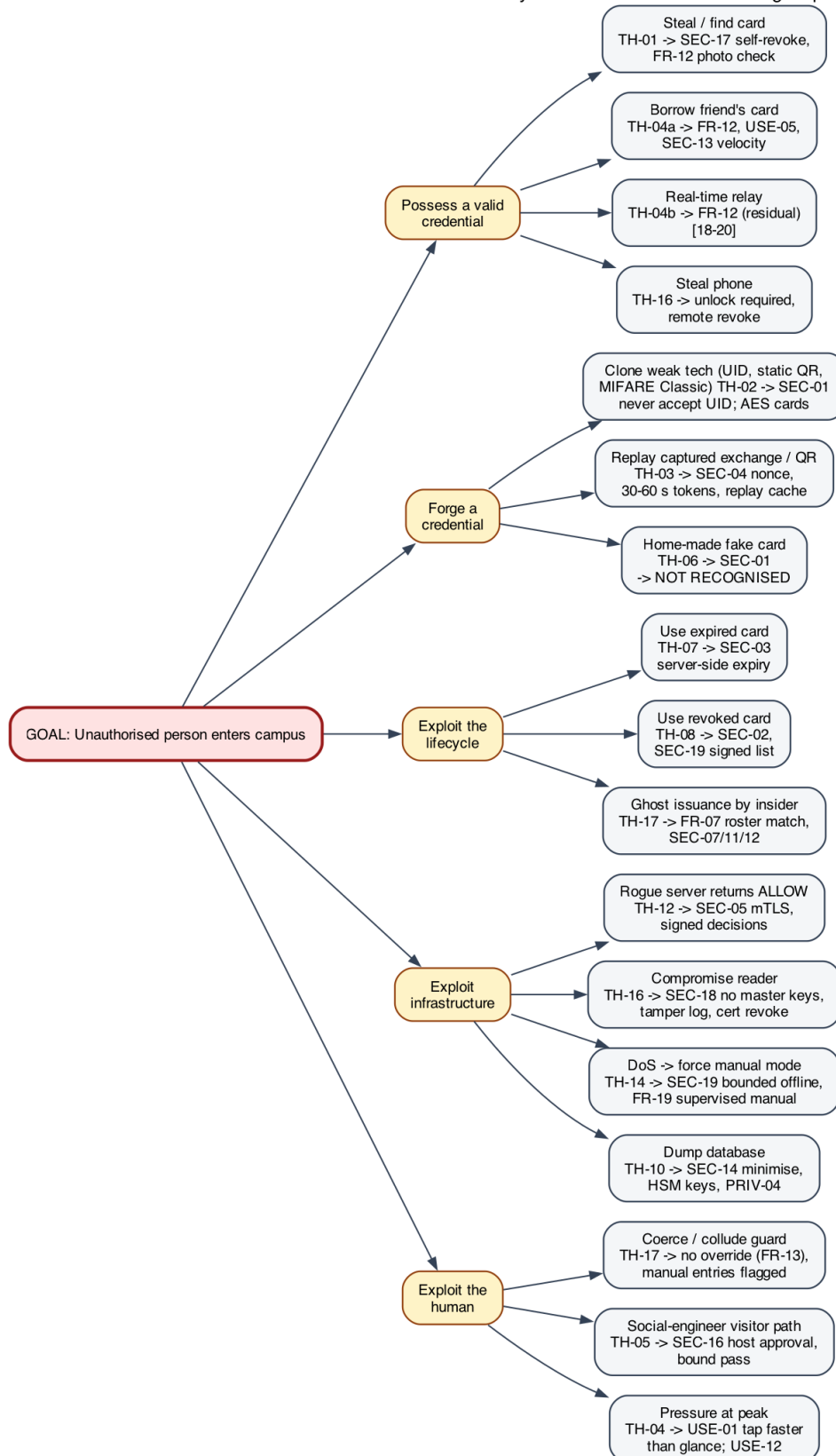


Figure J-9. Attack tree